

Q1) Explain the difference b/w authentication & authorization.

Ans → The difference between Authentication and authorization are given as :-

Before difference let have a basic idea of Authentication and authorization.

Authentication is the process of verifying who user is, while authorization is the process of verifying what they have to access to.

Authentication

- 1) Determines whether users are who they claim to be
- 2) challenges the user to validate credentials (for example, through passwords, answers to security question or facial recognition)
- 3) usually done before authorization
- 4) Generally, transmits info through an ID token
- 5) Generally governed by the open ID connect (OIDC) protocol
- 6) In short "Who are you"

Authorization

- 1) Determine what users can and cannot access
2. verify whether access is allowed through policies & rules.
- 3) usually done after successful authentication
- 4) Generally, transmits info through an Access token.
- 5) Generally governed by OAuth 2.0 framework.
- 6) In short "What are you allowed to access."

Q.2

Ans→

1. ~~Protect user~~ if the ~~database~~ is ~~compromised~~
if ~~attacker~~ steal the ~~database~~, they

Q.2 Why should passwords never be stored in plaintext?

CS B24047

Ans→ passwords should never be stored in plaintext because anyone who gains access to them can immediately use them. Here are the main reasons:-

1. Security against data breaches

2. Protect user privacy

many people reuse passwords across multiple websites. A leaked plain-text password could allow attackers to access the user's email, bank or social media accounts.

3. Insider threats

4) Compliance with security standards

→ security framework and regulation (such as PCI DSS and many industry best practices) requires passwords to be protected rather than stored in plaintext.

Q → 3]. What is the purpose of password hashing? (CSB24047)

Ans: The purpose of password hashing is to protect password by converting them into a fixed-length, unreadable value (called a hash) before storing them. This ensures that the original password is not stored and cannot be easily recovered.
purpose of password hashing is given as :-

1. protect user passwords
2. prevents password theft
3. verify password securely
During login, the system hashes the password entered by the user and compares it with the stored hash. If they match, the user is authenticated.
4. Enhance overall security
using unique salt for each password prevents attackers from using precomputed hash table (rainbow tables).

Q → 4. How does duplicate login prevention improve security?

Ans: Duplicate login prevention improves security by allowing only one active session per user account, reducing unauthorized access, account sharing and session hijacking.

EX: Abhay logs into her bank account on her laptop.
some one else tries to log into same account from another device.

The bank either (1) Block second user

(2) Logout Abhay & notify him about account access.

^{helps} This prevents unauthorized simultaneous access.

Q. suggest two additional security improvement for your app

Ans → Two additional security improvement for my application are :-

- 1) Implement ^{at} TLS (Transport Layer Security) using python built in SSL module to wrap my standard TCP sockets.
- 2) While hashing password with SHA256 is massive setup from plaintext, it is still vulnerable to dictionary attacks and rainbow table attack. we will introduce password salting later in our code.